

Comprehensive Penetration Testing Report

Engagement Type: Full Red-Team Simulation

Prepared By: Red-Team Operator

Target Environment: Kali Linux → Windows/Kali VM Infrastructure

Date: Ongoing Assessment

Table of Contents

1. Executive Summary
2. Scope of Work
3. Methodology
4. Reconnaissance
5. Exploitation
6. Credential Access
7. Lateral Movement
8. Exfiltration
9. Findings & Risk Ratings
10. MITRE ATT&CK Mapping
11. Recommendations

Executive Summary

This penetration testing engagement simulated a real adversary targeting a Windows environment using Kali Linux. The engagement followed the standard attack lifecycle:

Reconnaissance, Initial Access, Post-Exploitation, Credential Dumping, Lateral Movement, and Data Exfiltration.

Key Achievements:

Credential Extraction

Successful credential extraction (NTLM & SHA1 hashes) using Mimikatz.

Remote Data Exfiltration

Remote data exfiltration using Exiftool.

Covert C2 Channel

Covert DNS-based command-and-control established using dnscat2.

Sensitive File Extraction

Sensitive file extraction including /etc/shadow.

Scope of Work

The following objectives were defined for this penetration testing engagement:

-  **Evaluate security of Windows VM environment.**
-  **Test credential protection mechanisms.**
-  **Perform controlled exploitation using industry tools.**
-  **Validate whether DNS exfiltration is possible.**
-  **Assess logging & monitoring capabilities.**

Methodology

This assessment is based on industry-standard frameworks:

PTES

Penetration Testing Execution
Standard

NIST SP 800-115

Technical Guide to Information
Security Testing

MITRE ATT&CK

Adversarial Model

Attack Flow Diagram

1

Recon

2

Initial Access

3

Exploitation

4

Lateral Movement

5

Exfiltration

Reconnaissance

Nmap scanning was performed to identify target surface:

```
nmap -A -sV
```

Services Identified:

SMB

Server Message Block protocol detected

RDP

Remote Desktop Protocol accessible

WinRM

Windows Remote Management enabled

Exploitation

Mimikatz was used to extract credentials from LSASS memory:

```
.\mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords"
```

Extracted Hashes:

NTLM Hash

```
209c6174da490caeb422f3fa5a7ae634
```

SHA1 Hash

```
7c87541fd3f3ef5016e12d411900c87a6046a8e8
```

Critical Finding: Credentials were successfully extracted from memory, indicating insufficient protection of authentication material.

MITRE ATT&CK Mapping

The following techniques were successfully demonstrated during this engagement:

Attack Phase	MITRE ID	Technique
Credential Access	T1003	OS Credential Dumping
Execution	T1059	Command Execution
Exfiltration	T1048	Exfiltration Over Alternate Protocol
Defense Evasion	T1027	Obfuscated/Encrypted Communication

Recommendations

Based on the findings from this penetration test, the following remediation actions are **strongly recommended**:

01

Enable Windows Defender Credential Guard.

Protect credentials from memory-based attacks by isolating secrets using virtualization-based security.

03

Implement DNS logging & filtering.

Monitor and restrict DNS traffic to detect and prevent covert command-and-control channels.

05

Enforce strong password policies.

Require complex passwords with minimum length requirements and regular rotation schedules.

02

Enable LSA Protection.

Configure Local Security Authority (LSA) as a protected process to prevent unauthorized memory access.

04

Deploy SIEM with LSASS-access alerts.

Implement Security Information and Event Management with specific alerting for LSASS process access attempts.

06

Remove metadata from documents.

Strip sensitive metadata from files before distribution to prevent information leakage.